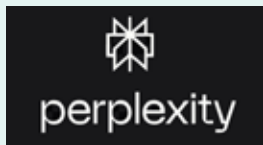


Perplexity open sources Numbat to secure AI coding agents

Perplexity AI has open sourced Numbat, a lightweight agent-detection and response layer designed to monitor and secure artificial intelligence (AI) coding agent activity across client endpoints. Distributed under the permissive Apache 2.0 License, the project has been contributed to the Open Secure AI Alliance.

Numbat is compiled as a single, static Go binary (without cgo) that operates seamlessly across macOS, Linux, and Windows platforms on both amd64 and arm64 architectures. Bypassing proprietary or agent-specific security models, Numbat functions as a universal cross-harness layer, normalising activity from saved developer sessions, live lifecycle hooks, and OpenTelemetry protocol over hypertext transfer protocol (OTLP/HTTP) log streams into a unified event schema.

For live detection and pre-action enforcement, Numbat utilises an endpoint-local Common Expression Language (CEL) rule engine alongside multi-step sequence evaluation and custom YAML rules. By integrating directly into agent 'pre-action' hook subsystems, it can synchronously block high-risk execution, such as destructive



shell commands or data exfiltration, before

impact. Enforcement blocking is disabled by default, requiring explicit opt-in configuration.

For post-incident forensics, Numbat reconstructs complete per-session timelines from on-disk session artifacts without requiring prior system instrumentation. It compiles portable, read-only case bundles containing SHA-256 manifests, versioned newline delimited JavaScript object notation (NDJSON) event records, and automated secret redaction.

Supabase builds Apache-licensed Evals to evaluate AI coding agents

Supabase has released Evals (supabase/evals) under the Apache-2.0 licence to evaluate AI agents, such as Claude Code, Codex, and OpenCode, against authentic engineering tasks derived from real support tickets and GitHub issues. Scenarios execute inside containerised Docker environments with actual command-line interfaces (CLI) and Model Context Protocol (MCP) interfaces, combining deterministic execution checks with LLM-as-a-judge scoring.

Evaluation spans three core dimensions: products such as Database, Auth, Storage, Edge Functions, Realtime, Cron, Queues, Vectors, Data API; topics such as RLS, security, migrations, SQL, SDK, observability, self-hosting, declarative schemas; and stages like build, deploy, investigate, resolve. The framework employs a dual-suite architecture comprising a published benchmark suite powering public leaderboards and an internal regression suite for daily failure-mode tracking.

Key findings show top-tier models, namely Opus 5 and Kimi K3, achieved 100 per cent pass rates unaided in the Build stage. Loading Supabase skills closed performance gaps for smaller models like Sonnet 5, which rose from 78 per cent to 100 per cent, though documentation retrieval varied sharply: OpenAI Codex checked ~8 pages per scenario versus Claude Code's ~2 pages. Agents also frequently defaulted to manual SQL migrations over declarative schemas and manual authentication checks over utility libraries like @supabase/server.

CISA's new framework establishes standardised rules for federal OSS adoption

The US Cybersecurity and Infrastructure Security Agency (CISA) has released a document titled 'Open Source Software: Security Principles and Practices' to help federal civilian agencies manage open source software risks. This publication directly fulfils policy requirements set out under Executive Orders 14144 and 14306, which instruct federal networks to adopt OSS securely while safeguarding their software supply chains.

CISA explicitly clarifies that open source code is inherently neither more nor less risky than proprietary alternatives. Its main advantage is code visibility, allowing agencies to audit source code directly rather than relying on commercial vendor promises. To streamline evaluations, the guide introduces the C4 Framework, giving administrators a structured approach to measure project trustworthiness, review security controls, and set acceptable risk limits before deploying OSS components.

The document sets clear operational rules for ongoing maintenance, detailing how to handle zero-day vulnerabilities when upstream maintainers have not yet provided fixes. Additionally, CISA draws a firm line between traditional open source software and open-weight AI models. Because many open-weight artificial intelligence (AI) licences lack visibility into training datasets, architecture, and alignment parameters, agencies are instructed to apply stricter, distinct evaluation criteria to AI systems.

To promote sustainable OSS engagement, the framework provides best practice guidelines for civil servants contributing to open source projects and outlines how procurement contracts should secure public-domain reuse rights for government-funded software. Open source cybersecurity experts, including former CISA leads, praised the guidance for offering a realistic, collaborative approach to software security while countering vendor-driven 'fear, uncertainty and doubt' (FUD).

Nokia open sources its AI-based video enhancement tech

Nokia has open sourced its Neural Network Post Filter (NNPF), bringing the first AI-based video enhancement technology into international video standards.